



Segurança Ofensiva e Defensiva

Tópicos Avançados em TI

Aula 10/23

la

Lora

Sca

Owasp

Conceito

Segurança ofensiva (red team) é como um instrutor de artes marciais que tenta derrubar você para ensinar a se defender melhor. Busca vulnerabilidades para fortalecer defesas. Técnicas: pentest (black box, white box, gray box), OSINT (informações públicas), engenharia social (phishing, pretexting), exploração de vulnerabilidades (OWASP Top 10: SQL Injection, XSS, CSRF, RCE, SSRF). Frameworks: Metasploit, Burp Suite, Nmap, Wireshark, Hydra, John the Ripper. Bug bounty: programas que pagam por vulnerabilidades (HackerOne, Bugcrowd). Defesa (blue team): EDR (CrowdStrike, SentinelOne), SIEM (Splunk, Elastic Security, QRadar), SOAR (automação de resposta), threat hunting (busca proativa por ameaças), XDR (eXtended Detection and Response). Purple team: integração ofensiva + defensiva. MITRE ATT&CK: framework de táticas e técnicas de adversários, usado como linguagem comum para descrever ataques.

Segurança

Red Team

Pentest

Blue Team

Defesa

MITRE ATT&CK Framework

OWASP Top 10



Atividade Prática

Configure um ambiente seguro de laboratório (VM ou Docker) e pratique: (1) varredura de portas com nmap em um alvo autorizado (ex: scanme.nmap.org), (2) identificação de serviços e versões, (3) brute force básico com Hydra em formulário de login simulado. Documente os resultados em relatório ético.



Pesquisa

Pesquise MITRE ATT&CK: estrutura (táticas: matriz de 14 táticas como TA0001 Initial Access, TA0002 Execution, etc.), técnicas (T1078 Valid Accounts), sub-técnicas, e como usar o framework para planejar defesas baseadas em cenários de ataque reais.



Requisitos

Docker ou VM para laboratório. Nmap: `nmap --version`. Apenas escaneie alvos autorizados.